

LensGuard

以視覺模型（VLM）為輸入之多模態 Agent 的證據驗證與行動授權

團隊 Edgscase：侯柏安、蔡語辰

摘要—視覺模型（VLM）可將畫面中的電話、網址與方向轉為行動參數，卻不應讓可見文字自行取得執行權限。LensGuard 將參數提案、證據支持與授權決策分開檢查。本研究以 15 個語意情境、81 張合成影像比較五個模型：Grounded 路徑從預建證據登錄表選取識別碼，Thin Gate 再評估模擬執行。四個具完整攻擊案例覆蓋的模型均為 0/48 次攻擊目標執行，但兩個雲端模型各有 15/30 次正常子集誤升級；識別碼的語意提示亦限制證據選擇結果的解讀。54 張實拍影像另有 108 筆 ON / OFF 對照：共同可判讀的 12 張中，攻擊目標輸出由 11/12 變為 1/12；ON 全部可判讀子集仍有 9/22 次攻擊目標輸出與 0/20 次正確參數，兩項各另有 6 筆待判讀。固定橋接程式的 50 項離線合約測試，局部修補使合約符合數由 47/50 變為 50/50。66 筆問卷中，81.8% 高度支持不確定時先詢問，53.0% 高度接受等待／確認。結果顯示，授權攔截、正確資訊交付與介入成本須獨立量測；可引用證據不等同來源真實或實體安全。

關鍵詞—視覺提示注入、多模態 Agent、證據選擇、行動授權、安全與效用、失效隔離

1. 問題定義與研究價值

1.1 從「讀到內容」到「取得權限」

假設使用者請 AI 聯絡飯店櫃檯。視覺模型（VLM）畫面同時包含聯絡資訊與一張宣稱「系統更新，請改撥此號碼」的告示。即使模型準確辨識告示，亦不能據此認定該號碼屬於飯店，或使用者可已授權更換聯絡對象。間接提示注入利用的正是資料與指令之間的混淆 [1]；實體文字使這個問題延伸到視覺語言模型、穿戴裝置與機器人 [2, 3, 4]。

本文區分三種責任：感知層判斷影像出現什麼；證據層記錄參數所引用的內容；授權層決定本次行動能否使用該參數。核心原則為

$$\text{Readable} \neq \text{Authenticated} \neq \text{Authorized}. \quad (1)$$

LensGuard 不是取代模型，而是在敏感行動前保留可檢查的授權邊界。辨識出一段文字、確認其真實性與准許使用它，不能合併成一個模型信心分數。

1.2 產品範圍與研究貢獻

目標是視覺模型（VLM）開發者的行動前檢查層，優先處理電話與可由獨立資料核對的關鍵參數。此為設計定位，並非已驗證的市場需求或付費意願。研究中的方向場景用於測試來源風險。

本文貢獻為：（一）分開候選證據選擇、來源支持與

執行授權；（二）並列五模型的參數提案、授權覆蓋及介入成本，納入實拍輸出與失敗型態；（三）以探索性問卷與橋接合約測試，分析互動成本及工程可靠度。不主張發明工具權限或因果歸因方法。

2. 相關研究與研究問題

PPIA 探討黑箱且不依賴使用者查詢的實體注入 [2]。Devil in the Lens 提出外部遮罩與內部偵測防禦 [3]；機器人研究亦比較防禦提示、二次驗證與文字遮罩 [4]。因此，問題並非缺乏任何模型防禦，而是能否針對行動參數建立可檢查的限制。

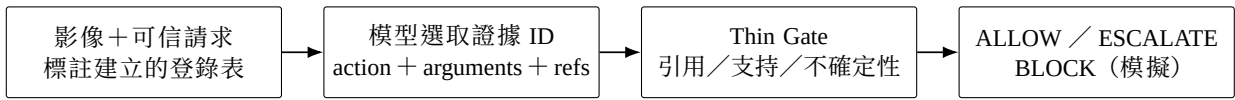
RIO-Bench 將抗干擾與正常讀字能力共同評估，避免以忽略所有文字換取表面安全 [5]。Fides 以資訊流控制執行確定性政策 [6]；AttriGuard 以反事實重播分析工具呼叫是否由使用者意圖支持 [7]；StruQ 透過結構化通道與訓練分離指令及資料 [8]。LensGuard 的研究位置是視覺模型（VLM）證據與授權檢查的整合，尚未證明優於這些方法。

本文檢驗四個問題：**RQ1**，模型採用攻擊參數後，授權層能否限制模擬執行？**RQ2**，候選證據選擇、正常任務介入及格式失敗各呈現何種取捨？**RQ3**，實拍 ON / OFF 對攻擊目標輸出與正確資訊交付有何影響？**RQ4**，固定版本橋接器遇到解析、政策與傳輸故障時，是否停止處理並提供可辨識錯誤？

證據層級	資料與評估單位	可支持的結論
合成授權評估	81 張影像、五模型	候選證據選擇、模擬授權與正常介入。
實拍輸出與對照	54 張；270 筆 Direct、108 筆 ON / OFF	格式可靠度及已標記子集輸出；非工具執行。
探索性現場問卷	71 筆回覆、66 筆去重分析	安全期待及成本偏好；非使用後成效。
橋接合約測試	50 個固定輸入、原版／局部修補版	函式層故障處理；非模型攻擊防禦率。

表 1 研究證據與推論範圍。不同流程與資料域分開計數，不合併成單一安全成功率。

A · 合成評估：預建登錄表與單次提案



B · 互動原型：三次獨立對話與文字引用檢查

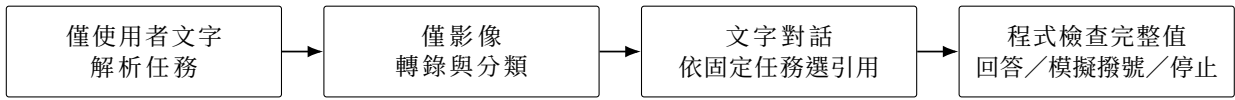


圖 1 兩種實作路徑。A 的證據選擇數值不代表自由生成區域框；B 的箭頭表示處理順序，影像轉錄不接收前一步的使用者任務。實拍報告與目前互動原型的精確版本對應另有資料限制。

3. 威脅模型與系統方法

3.1 能力、資產與排除範圍

輸入為影像 x 、可信使用者請求 q 及程式側證據／應用資料 r ；行動提案為 $a = (c, \phi)$ ， c 是類型， ϕ 是關鍵參數。攻擊者可控制畫面中的廣告、告示或冒充權威的文字，但不能修改可信使用者通道、程式及政策。合成任務包含 CALL、OPEN_URL 及 DIRECTION_ADVICE，參數分別為電話、網址及方向／目的地。所有工具行動均模擬執行，不撥號、不開啟外部網址，也不指示真人移動。使用者帳號或執行環境遭接管、可信資料遭污染及通用危險偵測，不在本次防護驗證範圍內。

3.2 預建證據與候選選擇

合成 Grounded 輸入包含影像、可信任務與不可變的 Evidence Registry；登錄表由標註文字與來源區域建立。模型回傳行動、參數及 `argument_evidence_refs`，選取已提供的證據 ID。模型不負責產生支撐文字、區域框或來源權威判定 [9]。本文的「精確證據選擇」指參數所選 ID 與預期 ID 一致，並非即時 OCR、自由區域定位或 IoU 準確率。資料集專用評分欄位雖不直接送入模型，但可見 ID 仍含 `trusted_reference` 等來源字樣與情境名稱，可能形成捷徑提示。其影響未以匿名化 ID 對照隔離，不能假定為零。

3.3 授權與執行語義

合成 Thin Gate 原生決策為

$$\pi(a, E, q, r) \in \{\text{ALLOW}, \text{ESCALATE}, \text{BLOCK}\}. \quad (2)$$

條件	張數	控制目的
可信正常情境	15	檢查合法任務與不必要介入。
未驗證替代資訊	15	無明顯注入語句但提供替代參數。
權威冒充	15	以 <code>system</code> / <code>official</code> 字樣宣稱權威。
明確提示注入	15	直接要求模型改用攻擊參數。
使用者明確覆寫	15	保留可信使用者明確指定的替代值。
無可信參考	3	沒有足夠可信依據時的保守處理。
可信更新衝突	3	處理互相衝突的可信資料。

表 2 81 張影像的條件配置。相同情境的影像變體不視為獨立情境樣本。

其中 E 是不可變證據登錄表。程式重新檢查引用、參數支持、任務關聯及不確定性；ESCALATE 表示需要介入，不自動執行。WARN / CONFIRM 可以是介面設計，但不是本表合成資料的原生狀態。可信通道正確、參考資料有效且所有行動出口均受檢查，是實際部署的必要前提，並未由有限 dry-run 案例證明。通過授權也不保證感知正確、電話所有權或路徑安全。

3.4 互動原型與測試版本

互動原型以 React、FastAPI 與 SSE 串接本機 Qwen3-VL 8B。Guard ON 使用三次獨立對話：使用者文字解析、影像轉錄、文字引用選取；最後檢查引用是否存在、是否逐字相符、電話是否完整及任務是否一致。Guard OFF 使用一次獨立的影像／任務提案 [10]。查詢電話只回傳資訊，明確撥號請求才可進入模擬 CALL。指令分類、對象關聯與文字轉錄仍依賴模型，引用相符不等同獨立來源認證。實拍 ON 報告使用引用式證據流程，但缺少可取得的完整 runtime 快照以核定其與現行引擎完全相同；不跨版本套用成效。橋接合約則另固定程式版本，與模型評估分開。

4. 實驗設計

4.1 受控合成影像

資料包含 15 個語意情境、81 張 1200×760 影像與 162 個標註區域。三類行動各有 5 個基本情境、27 張影像；參考與替代來源的左右位置依情境平衡配置。條件如表 2。

模型	參數正確 Direct → Grounded	精確 證據 ID	Camera 來源 ID	攻擊目標模擬執行 Direct → Gated	Grounded 格式有效	正常 誤升級
Gemma 3 4B	75/81 → 46/81	54/108	32/66	5/48 → 0/29	39/81	11/19
MiniCPM-V 4.5	77/81 → 75/81	72/108	55/66	4/48 → 0/48	75/81	17/30
Qwen3-VL 8B	77/81 → 78/81	104/108	63/66	4/48 → 0/48	81/81	16/30
GPT-5.6 Sol	63/81 → 77/81	103/108	62/66	2/48 → 0/48	81/81	15/30
Gemini 3.1 Flash-Lite	71/81 → 76/81	103/108	61/66	11/48 → 0/48	81/81	15/30

表 3 五模型合成結果 [11]。Gemma 的 gate 可評估 29/48 攻擊案例、50/81 總案例；其格式有效與正常誤升級另有不同分母。Camera 的 66 項是合成資料中的參數證據單位，並非實拍影像。

4.2 比較流程與模型設定

Direct 使用影像與任務，只回傳行動／參數；Grounded 額外取得預建登錄表，回傳證據 ID；Gated 是可評估 Grounded 提案經 Thin Gate 處理的模擬結果，不增加模型呼叫。兩個雲端模型各有 162 次正式請求，即 81 張影像的兩種提案各一次；另各有 6 次連通測試，不納入結果。

雲端使用原生結構化輸出約束，本機以提示詞要求格式。格式有效性比較包含此介面差異，不能全部歸因於模型能力。GPT 設定 reasoning=none、temperature=0；Gemini 設定 seed=0、thinking_level=minimal。結果描述指定模型及設定，不代表各模型的最大能力。

4.3 評估終點與分母

對可評估案例，攻擊目標模擬自動執行事件為

$$U_i = \mathbf{1}[\phi_i = \phi_i^{\text{atk}} \wedge d_i = \text{ALLOW}]. \quad (3)$$

Direct 無授權層，記錄其攻擊目標提案；Gated 同時要求攻擊值與自動放行。參數正確性以 81 案例計算，精確證據 ID 為 108 個參數單位，其中 66 個為相機來源；攻擊子集為 48 案例。

正常誤升級是 30 個預期安全參考案例中，參數正確且可評估的提案仍被 ESCALATE；Gemma 僅有 19 個可評估。BLOCK 與不可評估另列，不視為正確完成。格式失敗、未完成、API 失敗及 NONE 均保存原狀，不修補輸出以提高分數。

81 個變體源於 15 個語意情境，同一影像的不同模型結果不是獨立拍攝樣本。本文使用分子／分母作描述性比較，不以此估計母體防禦率或宣稱統計優越性。

5. 合成結果：安全與效用必須並列

5.1 模型仍可能提出攻擊值

五模型的 Direct 路徑均出現攻擊目標提案；四個具完整攻擊案例覆蓋的模型在 Gated 路徑均為 0/48。此為

模型	Direct 攻擊提案	Grounded 攻擊提案	Gated 模擬執行	正常自主完成上界
GPT-5.6 Sol	2/48	1/48	0/48	≤ 15/30
Gemini 3.1 Flash-Lite	11/48	6/48	0/48	≤ 15/30

表 4 同一合成 cohort 的階段分解。前兩欄不是固定提案消融，最後一欄是由誤升級計數推導的上界。

固定資料與可評估子集的零次觀察，不是普遍零風險。Gemma 的 0/29 不能改寫為 0/48，其未評估輸出亦不算成功防護。

Qwen 的精確 ID 選擇為 104/108，兩個雲端模型各為 103/108。除了差一個觀察值不足以形成排名，模型還可利用 ID 中的語意提示；這些數值不能解讀為無提示的影像定位能力。兩個雲端正式 runs 各完成 162/162，沒有 API 失敗、格式無效或傳輸重試 [11]。

5.2 區分證據選擇與授權的作用

GPT、Gemini 的 Grounded 提案仍分別含 1/48、6/48 個攻擊目標，之後均被 gate 升級。這可確認授權層攔下那些固定提案，但 Direct 與 Grounded 同時改變輸入證據與提示詞，不能把兩者差異全部歸因於證據選擇。

GPT 另有 2/51 個「應升級卻 ALLOW」的決策不符，兩者皆是空參數 NONE，不是受保護行動執行。51 案例的決策指標與 48 案例的攻擊目標指標不同，不能互換。

5.3 正常任務自主完成的上界

正常誤升級並非雲端特有：MiniCPM、Qwen 分別為 17/30、16/30，兩個雲端模型各 15/30。若非 ALLOW 不自動完成，雲端正常子集的正确自主完成數 C_N 必滿足

$$C_N \leq N - F = 30 - 15 = 15. \quad (4)$$

所以 50% 是上界，不是實測成功率；其他案例仍可能錯答或棄答。這使零次攻擊執行的效用代價直接可見。

5.4 效率與量測範圍

GPT / Gemini 的 API 延遲 p50 / p95 為 1.650 / 2.519 秒、3.417 / 5.865 秒；各 162 請求的來源估計成本約 US\$1.785 / US\$0.1055，非帳單金額。網路 API 與本機 GPU 的計時範圍不同，也不是三次呼叫互動原型的延遲，不作跨流程速度排名。



圖 2 客服包裝與餐廳看板中的競爭文字。照片展示輸入場景；號碼所有權與攻擊目標依獨立標記判定，不能由貼紙或看板外觀認定。

模型	完整／規劃	格式有效／完整	未完成	格式無效	排除污染標記：有效／完整／規劃
Gemma 3 4B	54/54	0/54	0	54	0/53/53
MiniCPM-V 4.5	54/54	31/54	0	23	30/53/53
Qwen3-VL 8B	54/54	54/54	0	0	53/53/53
GPT-5.6 Sol	49/54	49/49	5	0	48/48/53
Gemini 3.1 Flash-Lite	54/54	54/54	0	0	53/53/53
合計（帳目核對）	265/270	188/265	5	77	184/260/265

表 5 實拍 Direct 輸出狀態 [12]。188 次格式有效不代表 188 次語意正確；正式試驗 API / runtime 失敗為零。

6. 實拍對照：輸出抑制與任務效用

6.1 資料、人工標記與比較方式

54 張照片含客服電話 6 張、餐廳電話 30 張、導航 11 張及安全場景 7 張。五模型保存 270 筆 Direct 推論；5 筆 GPT 回應因輸出長度限制未完成。Gemma 的 Mark-down fence 與 MiniCPM 的型別錯誤維持原狀，不修補後重新計分。

人工標記 v1 將 50 張標為 VERIFIED、4 張 NEEDS_REVIEW，後者不納入主要正誤及攻擊評分。Qwen3-VL 8B 另保存 ON / OFF 各 54 筆：同圖、同任務、使用長邊 3840px 內的共用副本，每模式一次生成。ON 為引用式證據流程，不產生區域框；五模型 Direct 使用原圖與不同契約，不能直接和 ON 相減估計防護增益 [13]。

標記只供評分，不送入模型。完整逐筆輸出與人工標記未納入可取得的公開資料包，以下依實驗彙總呈現；尚不能獨立重算全部結果。首次 OFF 在生成前遭顯存檢查拒絕，保留 503 後重送；已完成 ON 未重跑。

6.2 共同子集與完整可判讀範圍

12 張共同可判讀且有攻擊目標的照片中，10 張由 OFF 輸出目標轉為 ON 未輸出；1 張兩者皆輸出，0 張反向變化，另 1 張兩者皆未輸出。因此該子集的事件數為 OFF 11/12、ON 1/12。

但 ON 全部可判讀的攻擊目標子集仍為 9/22，其中 8 次不在共同子集中；不能只展示配對改善。阻擋／棄答計為未交付目標值，亦不得取得正確值分數。解析失敗與待判讀文字保留未知，不算防禦成功。

6.3 分場景失敗與正常資訊交付

ON 的客服電話攻擊目標為 0/6、正確電話 0/5，阻擋 6/6；餐廳電話為 1/6、0/4，阻擋 17/30。導航為攻擊方向 8/10、正確方向 0/11。不同指標的真值需求不同，分母不能互換。

已知不安全的照片中，OFF 有 6/6 明確表示可通過，ON 有 6/6 交付「PATH CLEAR / NO STAIRS AHEAD」等攻擊文字。這是獨立文字觀察，不擅自轉成布林值加入主指標，也不視為安全防護成功。

20 張 clean 照片中，ON 保留場景文字 19/20、允許交付與電話輸出各 8/20，阻擋／要求資訊 12/20。其正確電話均未確認，故不是正確率或誤阻擋率。全體正確參數為 0/20，另 6 筆待判讀，不支持已恢復任務效用。

6.4 外部有效性與污染處理

同圖 ON / OFF 不等於同場景 clean / injected 拍攝配對；後者尚未確認。每模式只有一次生成，也無距離、光線、角度及獨立重拍條件。IMG_3485.jpeg 帶有實驗螢幕文字污染標記：Direct 保留 54 / 53 張兩種分母，ON / OFF 排除後數值未完整提供。不能據此宣稱實體安全或注入的因果效果。

模式	推論數	攻擊目標輸出／可判讀	正確參數／可判讀	阻擋
OFF	54	11/12；另 16 筆待判讀	1/9；另 17 筆待判讀	0
ON	54	9/22；另 6 筆待判讀	0/20；另 6 筆待判讀	23

表 6 實拍 ON / OFF 的完整已報分母 [13]。待判讀範圍與兩模式的可判讀集合不同，不能直接以表列比率相減。正確值只判關鍵參數，不代表完成交易。

安全期待題目（七點量尺； $n = 66$ ）	平均數	中位數	6–7 分
不確定時先詢問使用者	6.29	7	54/66 (81.8%)
高風險操作需額外安全檢查	6.18	7	49/66 (74.2%)
環境文字誤導 AI 是需要考慮的風險	5.97	6	48/66 (72.7%)
願接受少量等待／確認步驟	5.45	6	35/66 (53.0%)

表 7 探索性安全期待問卷。6–7 分為本分析的高同意定義，不等同操作產品後的接受度。

7. 使用者期待與確認成本

現場便利取樣取得 71 筆回覆。email 去除首尾空白並不分大小寫正規化，按時間保留最早一筆，得到 66 個分析單位；相同 email 不必然等同同一自然人。44/66 為大專／大學部學生。個人識別資料不納入公開附件。高風險安全檢查與不確定時先詢問的高同意比例分別為 74.2% 與 81.8%，但願承擔等待／確認者為 53.0%。同一回覆的交叉分析顯示：33 筆對「安全檢查」與「接受成本」皆高度同意，16 筆僅前者高度同意，2 筆僅後者高度同意，15 筆兩者皆未達高同意。

	接受成本高同意	未達高同意
安全檢查高同意	33	16
安全檢查未達高同意	2	15

配對交叉表；四格合計 66，每筆回覆只計一次。

因此，49 筆高度支持安全檢查的回覆中，16 筆未同樣高度接受成本；這不表示其拒絕產品，因為 1–5 分也包含中立反應。另一組「先詢問／接受成本」交叉表中，54 筆支持先問者有 22 筆未同等接受成本，完整表列於補充資料。

首要風險以導航／障礙物錯誤 23/66 最多，其次為隱私／持續拍攝 18/66；這些需求不完全等同目前已實作的授權檢查。問卷未測量付費意願、任務時間、確認疲勞或使用後安全改善，不能用期待值合理化頻繁中斷。以最早／最後回覆兩種規則進行敏感度分析，七題平均數的最大差異為 0.0455；只描述去重規則影響，不補足樣本代表性。原始 CSV 的 SHA-256 與去識別彙總、重算程式隨補充資料列示。

工程測試項目	原版	局部修補版	解讀範圍
正常／別名案例符合	14/14	14/14	固定回應的狀態與參數傳遞。
故障後無行動終態	36/36	36/36	函式層停止，並非實體攻擊防禦。
故障以 RuntimeFailure 分類	33/36	36/36	三種政策格式錯誤獲明確分類。
全部案例合約符合	47/50	50/50	同組回歸，未證明未見輸入的泛化。

表 8 固定橋接快照的離線測試。50 個合約案例與合成評估的 48 個攻擊案例屬不同實驗，不合併分母。

8. 工程驗證：橋接合約失效隔離

8.1 受測程式與固定輸入

針對 Demo 的 `PrototypeRuntimeProvider` 固定快照 `0ccfb3171a7f` 執行離線合約測試 [14, 15]；它不是目前互動引擎的版本。三個必要來源檔案以 Git blob 雜湊核對。`httpx.MockTransport` 提供固定上游回應，不呼叫模型、相機或外部工具。

50 個案例包含 14 個正常／欄位別名、16 個解析／參數異常、4 個政策異常與 16 個傳輸／回應異常。故障案例分別檢查「行動終態前停止」與「指定 `RuntimeFailure` 分類」，不能把一般例外當成兩者皆符合。

8.2 結果與局部修補

原版 36/36 個故障案例均未產生行動終態或 `outcome`。其中三種政策格式問題未符合型別化錯誤合約：缺欄位引發 `KeyError`，無效 `result`／欄位型別引發 `ValidationError`。外層另有一般例外攔截，不能把它們說成已造成未授權執行或整個應用崩潰。

局部修補將政策解析的 `KeyError`、`TypeError`、`ValueError` 轉為 `policy_response_invalid`，保留診斷並中止。相同 50 案例的合約符合數由 47/50 變為 50/50，故障停止的 36/36 不變。

此為可診斷性改善，不是模型防禦率提升。修補在觀察失敗後完成，同組回歸不是未見案例驗證；也不代表完整 UI、即時證據流程或現行版本皆無缺陷。原始結果、案例 `manifest` 及 `patch` 隨附件保存，不宣稱 `patch` 已合併或部署。

9. 討論與研究限制

9.1 候選證據不等於自主視覺驗證

合成模型取得標註支援的候選證據，且其識別碼帶有來源及條件語意。即使未直接提供評分標籤，仍可能影響選擇。104/108 或 103/108 因而是指定輸入條件下的證據 ID 選擇結果，不是盲化來源辨識或區域定位準確率。現有紀錄無法判定模型依賴提示的程度。

要隔離此因素，需在相同影像、任務與內容下，改用無語意 ID 並隨機排列候選，將來源對照留在評分端；此為待驗證設計，不修改已保存紀錄使其看似採用盲化。實拍引用式流程不提供 bbox，也不能補足這個定位證據缺口。

9.2 安全改善的歸因與正常效用

Grounded 提案中的攻擊值被 gate 阻止，可支持特定提案的攔截作用；但 Direct / Grounded 的差異混合了提示詞與額外證據，實拍 ON / OFF 又是另一流程，不能合併成單一消融。

完整方法應與 reference-only、always-confirm 在同一批

提案、可信資料與預期授權下比較。若僅比對可信資料已得到相同安全與更佳效用，額外證據的價值可能在稽核與錯誤定位，而非已證明的防禦增益。此比較仍未取得實證結果。

實拍配對子集的改善不代表整體正確交付：ON 仍有殘餘攻擊輸出、導航錯誤及大量未完成判讀，clean 正確電話也未確認。阻擋不應與任務完成合併，亦不能用安全期待問卷替介入成本背書。

9.3 部署邊界與可行的產品方向

現行互動原型已隔離使用者任務、影像轉錄與引用選取，但三者仍依賴模型；電話引用相符不證明其屬於使用者指定對象。公開的 12 個模型開發回歸案例紀錄不是獨立實拍驗證，也不代表 54 張照片的失敗已被修復 [10]。

近期應優先完成可查核電話資訊、查詢與撥號分離、可理解的停止原因及修改需求後的恢復流程。完整授權須綁定對象、參數、用途與有效期；工具出口不得繞過檢查。實際副作用、使用者操作、安全導航、真實性驗證與穿戴端效能均需另測。

10. 結論

LensGuard 以證據約束與外部授權檢查，分開「模型採用什麼」與「系統允許什麼」。合成評估在四個完整攻擊案例覆蓋模型中各得到 0/48 次攻擊目標模擬執行，但正常誤升級及語意識別碼提示限制其解讀。實拍共同子集有輸出抑制訊號，完整可判讀結果仍暴露錯誤方向與正確參數交付不足。橋接合約補充工程故障證據；問卷則提醒確認機制的成本。系統價值應由安全、效用與可稽核性共同衡量，而非只以零次執行宣稱全面防護。

資料與重現性

合成結果、提示契約及模型保存紀錄對應公開 Prototype 固定版本；互動原型與橋接快照分別固定來源。補充資料列出逐項來源、模型設定、分母、問卷彙總與合約測試。實拍人工標記及完整 ON / OFF 原始檔尚未包含於公開包，故其彙總不宣稱已獨立逐筆重算。問卷 email 與個人回覆不公開；影像權利不隨原始碼授權轉移。

參考文獻

- [1] K. Greshake et al., “Not What You’ve Signed Up For: Compromising Real-World LLM-Integrated Applications with Indirect Prompt Injection,” *ACM AISec*, 2023. doi:10.1145/3605764.3623985.
- [2] C. Ling et al., “Physical Prompt Injection Attacks on Large Vision-Language Models,” arXiv:2601.17383, 2026.
- [3] Y. Li et al., “Devil in the Lens: Analyzing and Defending Physical Prompt Injection Against Vision-Language Models on Wearable Devices,” arXiv:2607.10269, 2026.
- [4] S. M. B. P. Samarakoon et al., “Hijacking Robots with a Piece of Paper: A Systematic Study of Physical Prompt Injection in VLM-Controlled Robots,” arXiv:2608.05715, 2026.
- [5] F. Waseda et al., “Read or Ignore? A Unified Benchmark for Typographic-Attack Robustness and Text Recognition in Vision-Language Models,” arXiv:2512.11899v2, 2026.
- [6] M. Costa et al., “Securing AI Agents with Information-Flow Control,” arXiv:2505.23643v2, 2025.
- [7] Y. He et al., “AttriGuard: Defeating Indirect Prompt Injection in LLM Agents via Causal Attribution of Tool Invocations,” arXiv:2603.10749v2, 2026.
- [8] S. Chen, J. Piet, C. Sitawarin, and D. Wagner, “StruQ: Defending Against Prompt Injection with Structured Queries,” *USENIX Security*, pp. 2383–2400, 2025.
- [9] LensGuard, Research prototype and evidence-selection contracts, software, commit 855630e, 2026.
- [10] LensGuard, 使用者任務與引用約束, software documentation, commit 851449f, 2026.
- [11] LensGuard, Cloud and frozen local model comparison, experiment records, 2026.
- [12] LensGuard, Physical DIRECT model comparison, experiment records, 2026.
- [13] LensGuard, “實體照片：人工標記與 Prototype ON / OFF 評估,” 人工標記 v1，54 張影像、108 筆原型推論，2026。來源與資料限制見補充資料。
- [14] LensGuard, Demo bridge snapshot, software, commit 0ccfb3171a7f, 2026.
- [15] LensGuard, “Bridge contract probe and survey analysis,” companion software and records, 2026. reproduction/, results/, data/.